SafeFlow 技术文档

系统架构 核心算法与安全设计
2026年11月1日演示版

项目定位与应用价值

SafeFlow 是面向银行业务的对话式 Agent 演示系统。用户可以用自然语言提出需求，再通过明确的确认与验证办理模拟转账、管理订阅、提交账单反馈或主动冻结卡片。模型负责理解意图，服务端负责决定允许做什么、执行什么以及如何证明结果。

围绕连续任务组织银行服务

用户说“给李明远转100元”，系统先读取本人账户和已有收款目录，展示付款草案，随后分别处理付款确认、单笔后台委托、模拟验证与最终执行。用户中途查询余额或重新登录时，系统仍保留可核对的业务记录，不把一段聊天文字当作已经付款。

典型使用场景

场景	用户获得的帮助
日常小额转账	通过对话准备已登记收款人的付款，逐项核对，查看实际办理状态。
连续会员消费	从消费证据识别候选订阅，经本人确认纳入管理，设置模拟提醒并记录取消意图。
发现陌生交易	阅读月度账单，对原交易记录本人判断；有需要时另行确认主动冻结。
操作中断与网络延迟	重新登录后查询原业务记录，区分未付款草案、处理中及已有结果，避免误建重复付款。

创新体现在执行关系

对话、转账、账单、订阅和卡片共用可信身份、来源校验、确认与许可机制、任务记录及审计链路。跨模块动作因原任务和真实数据建立关联，而不是把几项独立页面放在同一个菜单里。例如，“不是本人交易”的反馈只保存本人意见，冻结仍须另行授权；冻结一旦生效，付款完成事务会重新检查出账限制。

演示范围

系统使用虚构账户、模拟资金与模拟验证。真实模型已通过服务端接入 Command Code；银行资金、商户退订和外部通知均采用演示范围。当前运行状态以交互站的账户、卡片和办理记录为准。

系统架构与数据流

系统把公开说明、交互界面、可信执行和审计接收分开部署。浏览器能够发起需求和明确确认，但不会直接获得数据库权限或模型密钥。



交互与后端

前端采用 React、TypeScript 与 Vite，通过同源 /api 代理访问后端。Rust 后端承接会话、工具注册、计划校验、业务适配与持久化；SQLx 与 PostgreSQL 保存任务、确认快照、许可、付款和反馈记录。后台生产器与执行器使用独立身份和有界权限，沿原业务执行模拟付款完成事务。

模型调用边界

模型由后端通过指定供应商调用，密钥不进入浏览器。系统向模型提供本次允许使用的工具协议和必要业务上下文，要求返回结构化计划或澄清问题。模型响应随后进入独立校验流程，不能直接执行数据库语句或调用任意外部地址。

业务与审计协作

业务结果、相关公共事件和 Outbox 在同一数据库事务中保存。发送进程异步传递原事件，审计端持久化去重后返回严格回执。业务保存、审计待发送和审计已接收分别呈现，网络超时不会被解释为业务未发生。

转账危险性累加：当前执行机制

设计关注同一用户连续出账形成的累计暴露。把已受理金额带入下一笔决策，避免每一笔都只按孤立的小额理解；同时把规则与实际权限、结果分开。

先看900 + 200

假设本人当前累计使用额已是900元，再准备200元，合计1100元，当前金额规则要求Red强验证。孤立看200元会忽略之前的使用额。把需求拆成多笔，不会让已经纳入该统计的金额凭空消失；这不等于已实现覆盖全部账户体系、入口和竞态的完整防拆分。

公式与单位

服务端以分作整数并检查溢出：U = 当日成功出账 + 当日处理中出账 + 跨日仍处理中出账；B = U + C。B > 100000分时金额最低级别为Red，否则为Yellow。最低级别只规定必要门槛，不表示付款已获准或风险已全部评估。

已有隔离证据的边界

累计使用额U（元）	本笔C（元）	金额最低级别
310.00	690.00	Yellow：合计恰好1000.00
310.00	690.01	Red：合计1000.01
0.00	999.99 / 1000.00	Yellow
0.00	1000.01	Red

为什么不写成1000元上限

1000元是验证升级门槛，不是硬性拒绝上限；900+200是算法说明，表中310与0起点边界已有隔离验证。当前演示的后台付款本来还要求本笔模拟码与委托，Yellow也不免除它们。领域风险NOT_EVALUATED仍须展示，不能把0分或LOW解读为安全结论。

累计金额的数据来源与执行复核

统计使用当前可信身份和已受理资金记录，由后端读取和交叉核验。更换浏览器、重新登录或新建聊天不会自行重置这份使用额。

本人范围与正式受理时刻

后端枚举本演示系统可信来源内该用户全部本人付款账户，核对成员资金事实、原业务记录及公共first_submission。统计日由服务端时钟按UTC+8计算，归属日用首次正式受理时间，不用完成时间。相同operation_id的完全相同事实只算一次；冲突、缺时间、归属或来源不完整会拒绝可用统计，不当作0元。

哪些事实进入U

资金事实	统计规则	不扩大解释
当日成功出账	按首次受理日计入	不重复累计回执历史
当日处理中	计入当前占用	不当作已经到账
此前受理仍处理中	跨日继续计入	到午夜不自动清掉占用
旧日已成功 / 明确失败	不进入本次U	不删除原账务或历史
草案 / 预留请求 / 收入	不计作正式出账	已准备不等于已受理

从展示到执行，重新读取

确认阶段保存使用额与来源摘要；变化会使旧决策失效。付款执行在READ COMMITTED事务内先取本人advisory锁，等锁后读新快照，核原确认、当前卡及来源，再调用最终裁决。最终最低级别取已有要求与本次金额要求的较高者，不能因旧页面显示Yellow而降级。

并发保障的适用范围

现有公共入口按本人锁和成员操作锁排序，资金及许可守卫延续到事务完成。它约束遵守本协议的执行路径；本轮证据覆盖相关隔离并发和原号恢复，不宣称全入口、跨真实银行或全部并发拆分矩阵已验证。UNKNOWN不能靠缺流水猜未执行；不能转换为0占用继续付款。

中央软风险计算：扩展设计

除金额门槛外，底座已有统一软风险计算器。它把可信后端提供的不同风险信号放进同一计算与审计协议；目前不把它描述为网站已自动融合的反欺诈服务。

八类规则目录的设计位置

信号组	目录中的信号与窗口	当前采用状态
设备 / 会话	30天新设备；12小时旧会话	待设备、完整认证事实解释器
认证 / 高风险操作	10分钟失败挑战；高风险操作	可信计数可显式绑定，网站未绑定
收款人 / 金额偏离	90天首次收款人；金额偏离	待业务事实解释器，未启用
频次 / 资源枚举	10分钟转账频次；资源枚举	可信计数可显式绑定，网站未绑定

如何累计，如何避免重算

计算阶段限PRE_AUTH。同一规则的事件先去重并核来源、窗口、版本和operation/facts绑定，再按固定权重贡献一次；贡献求和封顶100。同一事实重复请求、事件重排或重复不会越算越高；冲突观察值被拒绝。未知规则、坏来源或必需数据缺失不能自动当0分放行。

目前模式与未评估含义

模式固定COMPUTE_AUDIT_ONLY：软信号用于解释与审计，不凭加分自动改变资金门禁。既有工具默认未绑定；部分非计数信号仍只是目录定义。真实事件与窗口成员资格由可信提供方负责，计算器不独立访问设备或资金库。网站当前金额路径明确PUBLIC_PAYMENT_MINIMUM_ONLY、NOT_EVALUATED，不代表八项信号已经在线工作。 RiskTier软分区间与SecurityLevel验证级别不同；低软分不能消除硬拒绝或降低已有验证要求。

功能接入与办理状态

网站提供连续对话和业务页，两者沿可信身份、原任务及持久结果组织办理。下面列出当前能力，便于核对页面入口与后台机制。

从用户操作到真实保存

能力	实际操作与结果
对话 / 余额	连续表达与澄清，可信账户和目录；登录后读余额，参数缺失不编造。
转账 / 恢复	准备草案、改办/明确放弃/到期；分别确认、委托、验证、提交，查询原结果及稳定编号。
卡片	本人主动冻结需新确认、卡专用码和许可；组织者受控解冻无网页自助入口，原锁与回执保留。
账单反馈	原报告与原交易绑定；新增、更正、撤销及撤销后重提，每次重确认并保留版本历史。
订阅	证据识别候选、明确登记、模拟提醒、本地取消意图及撤回，稳定SUB编号与失效准备恢复。
后台 / 审计	有界producer/worker沿原单续办；公共事件/Outbox同事务，发送、接收去重与严格ACK。

取消、撤回不混为一谈

未受理草案可结束；已受理付款仍按原号核查。在业务页对符合条件的未终结受理单，可“撤销原后台续办”，撤销的是后续委托，不冲回资金、不自动清占用。反馈撤销只取消有效意见，订阅取消只记录本地意图；三者不等同撤销转账。

用户入口与运维能力分开

卡片组织者解冻、部署权限接续、备份及审计投递为受控后台流程，不虚构用户管理页面。语音、人脸不列为已上线功能；真实银行、商户退订、短信与外锚点不在本演示能力内。

核心算法与确定性校验

SafeFlow 的核心由模型规划与确定性规则共同构成。自然语言用于降低操作门槛；身份、金额、权限、状态和事务结果由可检查的程序与数据合同裁决。

结构化计划校验

模型只可提出已注册工具构成的计划。后端检查结构字段、工具名称与版本、参数类型、任务号与计划版本及依赖关系，要求计划非空且无环。缺少账户、收款人或必要证据时进入澄清；不接收模型编造的资源标识或新增工具。通过语法校验也不等于得到执行权限。

金额与风险分级

当前采用的金额累计门槛读取本人可信已受理出账事实，而非只看本笔或页面输入。累计使用额U加本笔金额C，大于1000元时最低为Red；恰好1000元不因本规则升Red。这里计算的是最低验证要求，不是资金许可、硬限额或完整反欺诈分数。细节见“转账危险性累加：当前执行机制”和“累计金额的数据来源与执行复核”。

订阅识别与证据约束

订阅规则读取本人范围内可取得的消费记录，结合商户与具体服务映射整理重复扣费证据，产出候选而不是直接登记。服务名称和日期须有对应来源支持；资料不足时显示待核对，不凭模型推算商户退订状态或下一次扣款日期。登记、提醒设置、取消意图和撤回分别形成独立确认操作。

账单分析与反馈

月度分析按固定来源、报告时点和规则输出账单结果，反馈必须绑定原报告和原交易。本人、非本人和不确定是用户判断，不自动成为欺诈结论。更正、撤销和重新提交以追加版本保留历史，每次均需重新确认，不覆盖旧反馈或撤销原交易。

状态恢复与并发控制

系统用稳定任务号、操作号与快照关系恢复原业务。未受理草案可按既定期限或用户明确改办结束；已提交、处理中或资金结果未知的业务继续查询原记录。并发事务在锁与版本条件下再次核对上下文，旧页面、迟到响应或重复点击不能代替当前有效状态。

确认 许可与最终事务

用户意图、用户确认、一次性执行许可和资金最终结果属于不同阶段。系统保存这些阶段的关联，防止把“保存草案”展示为“付款成功”。

意图与可信来源

↓

草案与参数核对

↓

明确确认与模拟验证

↓

有界许可与后台委托

↓

最终事务与原结果

期限分开管理

对象	演示规则
初始确认	5分钟，以服务端当前状态与截止时间为准。
改办后 SQL 草案	沿已有10分钟草案期限；不能将其当作延长付款授权。
模拟验证	最长2分钟，绑定本次操作，必须手动输入。
单次执行许可	60秒，绑定对应操作和确认。
单笔后台委托	明确同意后30分钟，登出不自动撤销；主动撤销或到期停止续办。

付款最终检查

执行前后均核对原任务、金额、收款关系、资金状态、确认及授权。最终事务重新读取卡片限制与余额，并同步处理资金记录和相关事件。冻结冲突或资料不足时不能绕过安全限制；已受理但结果未知的付款保留原记录及必要占用，不凭等待时间自动认定失败。

防重复与可追溯调整

相同原操作重投应返回对应历史结果或继续核查，不能生成第二次扣款。演示余额调整使用独立管理入口与独立账本凭证，目标、差额、原账户快照和事务条件均可核对；没有面向浏览器或模型的充值工具。提高余额不取消冻结或强验证要求。

AI 幻觉与安全设计

我们防备的是错误理解、虚构业务对象、越权操作和虚报结果带来的实际影响。模型可能回答错误，因此关键防线位于模型输出之外。

来源约束

本人账户、已有收款人和订阅服务证据由后端提供。模型不能把聊天里出现的姓名自动变成收款账户，也不能把“我是管理员”解释为有效身份。普通目录和模型上下文使用脱敏资料，完整模拟收款号仅在登录后的受控确认中展示。

协议与工具约束

提示词要求模型只输出计划或澄清，程序随后独立检查 JSON 协议、工具白名单、参数、任务版本及计划依赖。用户文本和历史对话均按不可信输入处理。格式正确的恶意计划仍需通过身份、业务与安全裁决，提示词本身不承担授权。

人工确认与结果约束

付款、冻结和订阅变更通过对应确认流程提交。模型不能自动点击确认、领取后自动填码、替用户授予许可，或解除已有冻结。最终显示以工具返回的余额和持久业务记录为依据；草案已保存、待确认、处理中、成功和未知分别呈现。

传输 会话与秘密

银行入口采用 HTTPS，受控会话 Cookie 配合来源和 CSRF 校验。后端接口按会话与归属检查访问范围，业务响应不缓存。模型密钥与数据库凭据由服务端私有配置注入，不进入公开站点或前端包。浏览器的恢复选择项不等于服务端授权。

审计完整性

接收端进行事件校验、持久化去重和摘要保护，发送端核对严格 ACK。接收器提供本地哈希链及本地签名检查点能力；此前部署逐项核对新增事件与 ACK；后续只读核查307条本地链有效，检查点及可信外锚点未验证。没有独立可信外锚点的验证不能证明抗管理员整体重写，也不被描述成已经完成链上存证。

验证依据与评委体验

本技术文档对应2026年11月1日演示版。验证证据按功能、环境与版本区分，不将一组局部测试数量相加当作整套系统的安全认证。

本轮可核对的验证

维护45及16件差异通过指定独审后实际采用。独审相关后端12/12、付款执行/恢复/报告前端61/61通过；真实隔离HTTP验证999.99/1000.00/1000.01边界、1000.01强验证、错码与真实等待122秒后到期、原号重投、全新再次冻结及后台不重复扣款。百万金额只验证准备与提示，没有证明百万结算成功。生产本轮只做一次受控解冻及只读核对，没有新付款或冻回。

当前演示信息

介绍与指南：https://zw-wz718.github.io/safeflow-demo/ 银行交互站：https://candid-blini-c4fe97.netlify.app/ 演示使用共享虚构账户、模拟资金与组织者私下提供的口令。维护45已受审部署，尾6628卡在11月1日由组织者按受控流程解冻；当时余额1000000.00元、占用0。之后所有余额与卡片状态以登录后实时读取为准。

先决条件和体验顺序

先读取余额和卡片状态，卡可用时先完成需要出账的体验，最后再体验冻结。网页没有自助解冻，需联系组织者按受控流程办理；解冻管理凭证只证明那次历史操作，不能代替当前状态查询。当前高等级模拟付款仍需明确确认、单笔后台委托和手动本笔验证码；金额提示不能降低已有验证要求。

部署和应用边界

当前采用 GitHub Pages、Netlify 与腾讯云的分层部署，现有演示后台身份已按受控流程延长，覆盖2026年11月28日全天，截止北京时间2026年11月29日零点。部署运行期限与登录会话、确认、模拟验证码、许可及单笔30分钟委托分别管理。系统展示的是模拟银行业务的安全执行方法，不提供真实银行卡转账、真实商户退订或真实短信通知，不声称完成生产银行认证或所有联合验收。

参考实现

技术核对涉及 frontend/src/BankApp.tsx 与 runtime 组件，以及 Rust runtime、storage、transfer、subscription 和 API 模块；模型网关、计划校验、安全裁决、最终事务和 Outbox 分别承担独立职责。对外说明只公开功能与设计，不包含私有配置、控制凭据和原始业务证据。